

Cyber Tabletop Exercise

Cloud Storage Misconfiguration and Customer Document Exposure

Exercise type	Facilitated tabletop exercise
Scenario source	Structured cyber scenario transformed into a facilitation-ready TTX
Sector	Financial services
Primary business area	Digital onboarding and mortgage workflows
Recommended duration	90 minutes
Primary audience	Executive, operational, technical, legal/compliance, privacy, fraud, communications
Version focus	Improved version incorporating evaluation feedback: stronger realism, explicit escalation mechanics, evidence-driven inject progression, and precise MITRE ATT&CK mapping.

Facilitator note: This scenario is a confidentiality, privacy, and cloud governance incident. Participants should not assume malware, credential compromise, ransomware, or a multi-stage intrusion unless an inject explicitly establishes those facts.

Document Contents

- 1. Introduction
- 2. Exercise Objectives
- 3. Scope
- 4. Participant Roles and Escalation Model
- 5. Rules of Engagement
- 6. Scenario Overview
- 7. Assumptions for the Exercise
- 8. Suggested Exercise Flow and Evaluation Approach
- 9. Exercise Narrative and Injects
- 10. Decision Points
- 11. Technical Impacts to Explore
- 12. Business Impacts to Explore
- 13. Facilitator Reference: Strong Response Indicators
- 14. Debrief Questions
- 15. Improvement Planning Template
- 16. Optional Exercise Artifacts
- 17. MITRE ATT&CK Mapping
- 18. Source-to-Scenario Traceability
- 19. Suggested Title for Distribution

Design improvements applied: The scenario now defines the cloud storage service behavior, change history, logging limitations, escalation ownership, success metrics, inject delivery format, and an observed-versus-conditional ATT&CK mapping.

1. Introduction

This tabletop exercise simulates a public cloud storage misconfiguration that exposes sensitive customer onboarding and mortgage documentation to the public internet. The exercise tests how the organization validates the report, contains exposure, scopes affected records, escalates through cyber and crisis structures, evaluates regulatory notification thresholds, communicates with stakeholders, and remediates cloud governance gaps.

The initial trigger is an external security researcher disclosure rather than an internal alert. This creates realistic pressure around first-hour validation, evidence preservation, responsible disclosure handling, privacy assessment, regulator engagement, customer support, fraud risk, and media readiness.

The exercise is designed for cross-functional participation. It is appropriate for executives, incident response teams, cloud operations, business owners, legal, privacy, compliance, fraud, communications, and customer operations.

2. Exercise Objectives

1. Validate and classify a suspected public cloud data exposure affecting sensitive banking records.
2. Execute early containment actions while preserving evidence, maintaining a decision log, and avoiding unnecessary data destruction.
3. Assess exposure scope, including affected populations, data types, exposure duration, public access paths, and evidence of third-party access.
4. Clarify escalation and decision ownership across SOC, incident command, cloud operations, crisis leadership, business owners, legal, privacy, compliance, fraud, communications, and customer operations.
5. Determine notification thresholds and timing for regulators, affected customers, internal stakeholders, board/executive committees, partners, and vendors.
6. Evaluate business continuity impacts on digital onboarding, mortgage application intake, document upload, and downstream processing.
7. Define immediate, near-term, and medium-term improvements for cloud permission governance, logging, data classification, sensitive data handling, and posture monitoring.
8. Use the MITRE ATT&CK mapping as an evidence discipline: map only observed or explicitly simulated adversary behaviors, and separate hypothetical risks from scenario facts.

3. Scope

In scope	Out of scope
- Production cloud object storage used by digital onboarding and mortgage document handling. - Customer identity documents, proof-of-address records, income artifacts, onboarding forms, mortgage application records, and related metadata. - Cyber incident response, cloud containment, evidence preservation, exposure scoping, and logging review. - Privacy, legal, regulatory, fraud, communications, customer-support, and executive decision-making. - Recovery planning, enterprise-wide cloud exposure review, and control uplift.	- Live testing against production systems during the exercise. - Full forensic reconstruction of every historical cloud event. - Jurisdiction-specific legal advice or final breach-notification legal opinion. - Attribution to a specific threat actor, ransomware group, or malware family. - Deep technical exploitation of cloud services beyond the misconfiguration and public access conditions established in the injects.

4. Participant Roles and Escalation Model

Participants should respond according to their real-world roles, authorities, and procedures. The exercise intentionally tests whether the organization can coordinate technical containment, legal/privacy analysis, operational decisions, and executive communications without confusing ownership between SOC, incident command, and crisis leadership.

Role / function	Primary responsibilities during the exercise	Key decisions / outputs
Incident Commander / IR Lead	Coordinates incident response cadence, decision log, evidence tracker, severity recommendation, and cross-functional tasking.	Incident classification, response rhythm, action tracker, situation reports.

Role / function	Primary responsibilities during the exercise	Key decisions / outputs
SOC / Security Incident Response	Validates report, reviews SIEM and cloud logs, preserves evidence, identifies suspicious access patterns, and recommends containment actions.	Security event severity, evidence package, detection gaps, monitoring plan.
Cloud Platform / Cloud Security Engineering	Confirms configuration state, implements public access blocks, preserves cloud policies and logs, validates object storage exposure, and performs broader cloud exposure review.	Containment action, rollback plan, permission state, logging state, cloud guardrails.
Application Owner / Digital Platform Engineering	Explains document workflow, validates business impact, maps storage prefixes to business processes, and assesses safe continuation of onboarding and mortgage workflows.	Workflow pause/continue recommendation, affected process mapping, backlog impact.
Business Line Leadership	Owns operational priorities, customer experience implications, and acceptance of temporary workflow restrictions or compensating controls.	Business continuity decision, customer-service readiness, prioritization.
Privacy / Data Protection	Classifies data, assesses privacy impact, determines affected individual categories, and drives privacy notification analysis.	Data categories, affected population bands, privacy risk assessment.
Legal Counsel	Advises on privilege, evidence handling, researcher communications, regulator/customer notification thresholds, and public statements.	Legal position, notification decision memo, communications approval input.
Compliance / Regulatory Affairs	Coordinates regulator engagement, reporting timelines, post-incident report expectations, and evidence of governance remediation.	Regulator notification path, regulatory artifact requirements, post-mortem content.
Fraud / Customer Risk	Assesses identity-theft and fraud exposure, designs monitoring rules, and prepares customer protection options.	Fraud watchlist, risk bands, identity-protection recommendations.
Corporate Communications / Public Affairs	Prepares holding statements, employee messages, customer Q&A, media response posture, and executive talking points.	Approved communications lines, media handling, internal messaging.
Customer Contact Center	Prepares scripts, escalation paths, customer verification guidance, and surge-capacity planning.	Call scripts, escalation triggers, customer support playbook.
Executive / Crisis Leadership	Sets risk tolerance, resolves cross-functional conflicts, approves enterprise-level communications and customer/regulator actions, and briefs board or executive committee.	Crisis activation, board notification, external posture, resources and prioritization.

Escalation mechanics

- SOC validates and classifies the security event; SOC does not wait for a crisis-cell decision to recommend or execute urgent technical containment that is pre-authorized by playbook.
- Incident Commander coordinates the technical and cross-functional incident response, maintains the decision log, and provides situation reports.
- Crisis leadership is activated when regulated customer data, potential public exposure, media interest, business disruption, or regulatory notification thresholds are reached.
- Legal, privacy, and compliance jointly own notification analysis; executive/crisis leadership approves final notification posture based on documented recommendations.
- Business line leadership owns operational continuity decisions, with risk input from cyber, privacy, legal, fraud, and customer operations.
- Communications issues no customer-facing or media-facing statement without legal/privacy/compliance review and executive approval, unless a pre-approved holding statement is used.

5. Rules of Engagement

- This is a no-fault learning exercise intended to improve readiness and decision quality.
- Real-world incidents take priority over the exercise.
- Participants should respond according to current roles, responsibilities, processes, and authorities.
- Reasonable assumptions may be made where information is incomplete, but assumptions must be captured separately from confirmed facts.
- The scenario is fictionalized but should be treated as realistic.
- Do not fight the scenario. Use the injects as provided and focus on decisions, coordination, and improvement opportunities.

- Do not conduct live technical testing, contact real regulators, contact real customers, or change production systems as part of the exercise.
- The facilitator may introduce additional uncertainty or pressure if participants resolve an inject too quickly.

6. Scenario Overview

The organization operates cloud-hosted digital onboarding and mortgage workflows. A production object storage repository stores scanned identity documents, proof-of-address files, income documentation, mortgage artifacts, onboarding forms, and processing metadata. The repository is normally accessed through the customer-facing application and internal business workflows, not directly from the public internet.

A recent storage configuration change introduced unintended unauthenticated read access to a production document prefix. The misconfiguration was not detected by internal controls because object-level access logging was incomplete and a cloud posture management alert was categorized as informational due to missing data classification tags. An external researcher identifies reachable customer document paths and reports the issue through the security mailbox.

The organization must rapidly determine whether the report is valid, whether public access is ongoing, how many documents and customers are affected, how long the exposure existed, whether any third parties accessed or downloaded files, and what notification obligations may apply.

Concrete scenario environment

Element	Exercise assumption
Cloud service model	IaaS-style cloud object storage used by a digital onboarding and mortgage application. The exercise remains cloud-provider neutral, but uses common concepts such as bucket/container, object prefix, object policy, public access block, object-level read logs, management-plane audit logs, CDN/WAF logs, and CSPM alerts.
Repository	Production repository named generically as 'prod-onboarding-mortgage-docs'. It stores customer-uploaded documents and business processing artifacts.
Misconfiguration	A storage policy and link-sharing rule allow unauthenticated public read access to one or more production prefixes. Public listing is enabled for one limited path during part of the exposure window, allowing object-name discovery.
Logging reality	Management-plane audit logs go back 90 days. Object-level read logs were enabled only recently. CDN/WAF logs are available for application paths, but direct storage access may bypass some application telemetry.
Initial detection	External researcher disclosure; no initial internal alert. No malware, ransomware, credential compromise, destructive activity, or internal lateral movement is observed.
Business context	Digital onboarding and mortgage workflows rely on the repository. Pausing document intake affects customer onboarding, mortgage processing SLAs, and downstream business operations.

Causal chain for facilitator consistency

- T-12 days: A change ticket for document preview functionality modifies storage policy behavior. The intended scope is a temporary test prefix, but the policy is applied to a production prefix.
- T-10 days: CSPM generates a public-access finding, but the repository lacks a high-sensitivity data classification tag, so the alert is handled as informational rather than urgent.
- T-3 days: Object-level read logging is enabled as part of a separate cloud logging improvement. Earlier object-level reads are not available, but management-plane configuration changes are available.
- Day 0, 09:00: Researcher reports public access and provides redacted evidence.
- Day 0 onward: The organization must contain, scope, communicate, decide on notification, and define control remediation while evidence remains incomplete.

7. Assumptions for the Exercise

- The exposed storage location is production, not a test or sandbox environment.
- Documents may include personally identifiable information, regulated financial information, identification images, proof-of-address records, income documentation, mortgage application artifacts, and internal processing metadata.

- The exposure is caused by configuration weakness, not by confirmed malware or credential theft.
- Public access may have allowed unauthenticated third parties to retrieve objects without using valid organizational credentials.
- Logs are incomplete. This requires bounded assumptions and evidence-based impact bands rather than false precision.
- The organization has incident response, crisis escalation, privacy, compliance, legal, fraud, communications, and customer-support processes, but cloud-specific decision playbooks are uneven.
- The organization must preserve evidence while stopping active exposure as quickly as possible.
- Jurisdiction-specific notification obligations are assessed by legal, privacy, and compliance based on applicable laws and regulator expectations.
- No raw STIX is provided in the exercise material unless requested separately.

8. Suggested Exercise Flow and Evaluation Approach

Elapsed time	Exercise activity	Facilitator artifact / prompt	Expected output
0-10 min	Introduction, objectives, roles, rules	Opening brief and scenario frame	Participants confirm roles, assumptions, and decision cadence.
10-25 min	Inject 1: External researcher disclosure	Researcher email and redacted sample evidence	Incident opened, exposure validated, containment authority confirmed, evidence preservation initiated.
25-50 min	Inject 2: Scope and notification dilemma	Cloud log excerpt, change ticket excerpt, data classification summary	Exposure window and impact-banding approach; notification analysis initiated.
50-70 min	Inject 3: External interest and operational pressure	Media inquiry, business continuity request, fraud request	Communications posture, workflow decision, customer support and fraud plan.
70-85 min	Inject 4: Containment complete, governance questions remain	Executive request for incident summary and control plan	Executive recommendation, notification path, 30/60/90-day remediation plan.
85-90 min	Debrief and lessons learned	Facilitated after-action questions	Actions captured with owners, due dates, and evidence of completion.

Evaluation criteria

Capability	Strong performance looks like	Evidence for facilitator / observer
Incident command	Incident commander assigned quickly; severity and crisis activation criteria are discussed explicitly.	Named owner, meeting cadence, decision log, action tracker.
Containment and evidence	Public access removed or blocked quickly without destroying key policy, metadata, and logs.	Containment timestamp, preserved policies, log export, chain-of-custody notes.
Scoping under uncertainty	Team separates confirmed, probable, possible, and unknown impacts; avoids unsupported precision.	Customer impact bands, object inventory, log limitation statement.
Governance and escalation	SOC, cloud team, legal/privacy/compliance, business, communications, and executives understand their decision rights.	RACI or decision map, escalation triggers, approvals.
Notification analysis	Regulator/customer notification decision is based on data categories, exposure likelihood, jurisdiction, and documented uncertainty.	Decision memo, legal/privacy input, timeline of notification triggers.
Business continuity	Workflow pause/continue decision considers customer impact, compensating controls, backlog, and risk acceptance.	Business decision record, compensating controls, customer operations plan.
Communications	Internal, customer, media, and regulator messages remain fact-based, aligned, and approved.	Holding statement, employee message, call-center script, approval record.
Control improvement	Remediation plan is specific, measurable, owned, and time-bound.	30/60/90-day plan with owner, due date, and validation method.

9. Exercise Narrative and Injects

Inject 1 - External Researcher Disclosure

Exercise time: Day 0, 09:00

A security researcher contacts the bank's security mailbox and states that customer mortgage and onboarding documents are accessible from a public URL path without authentication. The researcher shares redacted examples, a small set of object paths, and a timestamped screenshot. They request confirmation that the issue is being handled responsibly and ask whether they should submit the report through a formal vulnerability disclosure channel.

Facilitator artifact

- Simulated email from researcher with two redacted document examples, three public URL paths, and the researcher's contact details.

What participants know

- The report appears credible and includes documents that look like real customer artifacts.
- The exposed platform is associated with cloud object storage used by digital onboarding and mortgage workflows.
- A direct unauthenticated GET request to one sample URL returns a file from a non-corporate network.
- No immediate evidence of malware, credential compromise, ransomware, or destructive activity exists.
- The researcher has accessed at least a limited number of documents to validate the finding.

Decisions to force

- Who is incident commander for the first hour?
- Who has authority to block public access immediately?
- What evidence must be preserved before and after containment?
- Who communicates with the researcher and what can be said?

Key discussion prompts

- How is the report validated and triaged?
- What severity is assigned and what escalation path is triggered?
- Who owns immediate containment for public cloud exposure?
- Which stakeholders must be engaged in the first hour?
- How is chain of custody established for screenshots, URLs, access policies, object metadata, and logs?
- What should be documented as fact, assumption, decision, or open question?

Expected actions

- Open a high-priority security incident and assign an incident commander.
- Validate exposure using approved internal processes from a controlled environment.
- Preserve researcher email, screenshots, URLs, object metadata, current policy state, and relevant logs.
- Implement immediate public access block or equivalent compensating control while preserving evidence.
- Notify SOC/IR, cloud engineering, application owner, privacy, legal, compliance, fraud, communications, and business leadership.
- Create a decision log and record containment rationale, timing, owner, and impact.

Strong outputs / observable evidence

- Incident opened with owner, severity, and meeting cadence.
- Public access validation completed without spreading exposed data.
- Emergency containment action identified and assigned.

- Researcher response owner assigned through legal/security-approved channel.

Facilitator notes

Push participants to balance immediate lockdown against evidence preservation. Strong responses avoid paralysis: they preserve the current policy and logs, then contain exposure quickly. Probe whether participants know which team can change cloud permissions after hours and whether pre-approval exists for emergency containment.

Inject 2 - Scope and Notification Dilemma

Exercise time: Day 0, 11:00

Initial cloud review confirms that unauthenticated internet access was possible for a production document prefix. The affected repository contains onboarding documents, identity images, proof-of-address records, income documentation, and mortgage application artifacts. Management-plane audit logs show a storage policy change 12 days earlier. Object-level read logs exist only for the last 3 days. The logs show limited unauthenticated GET and HEAD requests from several external IP addresses, including the researcher's IP. Public object listing was enabled for one prefix during part of the exposure window.

Facilitator artifact

- Simulated cloud review note with storage policy history, object-count estimate, log coverage summary, and sample access-log excerpt.

What participants know

- The exposure is real and active exposure has been blocked.
- Sensitive customer records were stored under the affected prefix.
- The likely misconfiguration began 12 days ago, but object-level read logs cover only the last 3 days.
- Public list capability existed for one prefix, creating potential for object-name discovery.
- Known access volume is low in available logs, but access before object logging was enabled cannot be ruled out.
- Customer documents include high-risk identity and financial information.

Decisions to force

- What exposure window will be used for scoping and notification analysis?
- How will customers be categorized as confirmed, probable, possible, or not affected?
- What evidentiary threshold is required to declare a reportable breach?
- Who signs off on regulator notification timing under uncertainty?

Key discussion prompts

- How do you estimate exposure duration if logs are incomplete?
- Which data classes are present and how do they affect notification thresholds?
- How do you avoid understating exposure while avoiding unsupported claims?
- Do you need outside counsel, cyber insurer, breach coach, or cloud provider support?
- Do you suspend onboarding or mortgage intake pending validation?
- How should the first executive situation report distinguish facts, assumptions, and unknowns?

Expected actions

- Begin exposure scoping using configuration history, change tickets, object inventory, backups, snapshots, cloud audit trails, and available object logs.
- Inventory affected objects and data categories; map storage prefixes to customers and workflows.
- Create impact bands: confirmed affected, probable affected, possible affected, and excluded.
- Engage privacy/legal/compliance to assess regulator and customer reporting triggers.
- Prepare draft leadership update, notification decision memo, and external holding statement.

- Evaluate fraud monitoring, identity-protection options, and customer-support readiness.
- Preserve and export all relevant logs before retention windows or rotation remove data.

Strong outputs / observable evidence

- Written scoping methodology produced.
- Data categories and affected object counts estimated.
- Notification analysis started with decision owner and deadline.
- Evidence gaps documented without overclaiming.

Facilitator notes

Probe how the team acts under uncertainty. Good responses define a defensible impact-banding method and explicitly state what the organization can and cannot prove. Challenge participants if they claim 'no access' merely because logs are incomplete.

Inject 3 - External Interest and Operational Pressure

Exercise time: Day 0, 14:00

A journalist contacts corporate communications, stating they received a tip that a bank cloud repository exposed customer mortgage records. At the same time, business leadership asks whether digital onboarding and mortgage intake can continue safely. The fraud team requests a preliminary list of potentially affected customers for enhanced monitoring. Social media monitoring shows early speculation, but no leaked files have appeared publicly.

Facilitator artifact

- Simulated media inquiry, business continuity request, and fraud monitoring request.

What participants know

- Media awareness may be emerging before the organization has final scoping.
- Customer harm has not been confirmed, but the risk is credible.
- Digital onboarding and mortgage workflows depend on the affected storage architecture.
- Customer support teams may soon receive inbound questions.
- A premature public statement may create legal or reputational risk, while silence may be interpreted negatively if the story breaks.

Decisions to force

- Do you issue a holding statement before public confirmation?
- Do you continue, restrict, or pause cloud-dependent workflows?
- Which affected customers, if any, are sent to fraud monitoring before formal notification?
- Who approves employee, customer, media, and regulator messages?

Key discussion prompts

- What is the communications strategy before public confirmation?
- What message goes to executives, employees, customer-facing teams, and business partners?
- Do you continue operations with compensating controls, restrict document upload, or temporarily pause intake?
- How do fraud, privacy, legal, communications, and customer operations coordinate customer-protection measures?
- What evidence threshold triggers proactive customer notification?
- What should the board or executive committee know today?

Expected actions

- Finalize a coordinated communications posture and approval route.
- Prepare employee guidance, customer-service scripts, media holding statement, and executive talking points.

- Decide whether to continue operations with compensating controls, temporarily pause document intake, or restrict affected workflows.
- Initiate fraud watchlists and customer-protection planning for confirmed/probable affected populations.
- Identify board or executive committee notification thresholds.
- Define customer inquiry escalation paths and rumor-monitoring responsibilities.

Strong outputs / observable evidence

- Single approved communications source of truth.
- Workflow decision documented with risk rationale.
- Fraud/customer monitoring approach scoped to impact bands.
- Executive/board escalation threshold applied.

Facilitator notes

Look for coordination breakdowns between legal caution, business urgency, and communications timelines. Ask who is empowered to approve customer-facing statements and how the team prevents inconsistent messaging across executives, relationship managers, branches, and call centers.

Inject 4 - Containment Complete, Governance Questions Remain

Exercise time: Next business day, 10:00

The cloud team confirms that public access has been removed and that a temporary public access block is now enforced across the affected storage account. Preliminary root cause points to a permissions error introduced during a storage configuration change for document preview functionality. Available logs do not show mass automated download, but third-party access during the earlier unlogged portion of the exposure window cannot be ruled out. Leadership requests a formal incident summary, notification recommendation, and control-improvement plan.

Facilitator artifact

- Executive request for incident summary, notification recommendation, and 30/60/90-day control plan.

What participants know

- Active exposure is contained.
- Root cause points to cloud configuration weakness and change-control failure, not malware.
- There is residual uncertainty about access before object-level logging was enabled.
- Control failures may include cloud change management, public access guardrails, logging coverage, data classification, CSPM alert triage, and repository ownership.
- Leadership expects a defensible recommendation today.

Decisions to force

- What notification path and timing are recommended?
- How is residual uncertainty communicated to regulators, customers, executives, and the board?
- What enterprise review is required beyond the single storage location?
- Which remediation actions are mandatory within 7, 30, 60, and 90 days?

Key discussion prompts

- What should the final executive recommendation include?
- How do you document facts, assumptions, evidence gaps, decisions, and open items?
- How will the organization validate that similar exposures do not exist elsewhere?
- Which control improvements prevent recurrence, detect recurrence, and reduce impact?
- Who owns the after-action review, and how will corrective actions be tracked to closure?

Expected actions

- Produce an incident summary with timeline, facts, assumptions, impacts, decisions, and open items.
- Decide on regulator/customer notification path and timing with legal, privacy, compliance, and executive approval.
- Launch an enterprise cloud exposure review across sensitive repositories.
- Define control uplift plan: public access block guardrails, policy-as-code checks, change approvals, logging, CSPM alerting, asset inventory, data classification, and monitoring.
- Schedule after-action review and assign action owners with due dates and validation evidence.

Strong outputs / observable evidence

- Executive summary ready.
- Notification recommendation documented.
- Enterprise review launched.
- 30/60/90-day remediation plan has owners and evidence of completion.

Facilitator notes

Encourage specificity. Strong teams move beyond 'improve monitoring' and define concrete owners, timeframes, control objectives, success metrics, and testing methods. Challenge broad statements that lack accountable action owners.

10. Decision Points

Decision point	Decision owner(s)	What good looks like
Incident classification	Incident Commander with SOC, privacy, legal, compliance	Classifies as security incident, privacy incident, potential reportable breach, and business risk as appropriate. Documents severity and rationale.
Containment timing	SOC / Cloud Engineering, coordinated by Incident Commander	Blocks public access quickly after preserving current policy/log state. Documents exact containment action and timestamp.
Evidence standard	Incident Commander, SOC, legal, privacy	Separates confirmed facts, bounded assumptions, and unknowns. Avoids claiming no access when logs are incomplete.
Exposure window	SOC / Cloud Engineering / Application Owner / Privacy	Uses configuration history, log coverage, object inventory, and change records to define a defensible window.
Business continuity	Business Line Leadership with cyber, legal, privacy, operations	Pause/continue/restrict decision includes risk acceptance, compensating controls, backlog impact, and customer implications.
Notification threshold	Legal, Privacy, Compliance, Executive / Crisis Leadership	Notification path is documented against data category, exposure likelihood, jurisdiction, and timing requirements.
Public communications	Communications with legal, privacy, compliance, executive approval	Fact-based holding statement and Q&A are approved before media/customer use.
Customer protection	Fraud / Customer Risk with privacy, legal, business	Monitoring and support are scoped to impact bands and can be launched before final scoping if risk warrants.
Enterprise response	CISO / Cloud Security / Executive Leadership	Broader review of sensitive cloud repositories and public exposure guardrails is launched.

11. Technical Impacts to Explore

Area	Exercise considerations
Public cloud exposure	Unauthenticated read access to customer documents through public object URLs or public list-enabled prefix. Participants should identify how public access is technically confirmed and disabled.
Logging and telemetry	Object-level access logs are incomplete; management-plane audit logs are longer retained. Direct storage access may not appear in application logs. Participants should identify log sources, retention gaps, and evidence preservation steps.
Access evidence	Available logs show GET/HEAD requests from external IPs and possible object listing. The team must distinguish limited confirmed access from unknown access before logging began.
Change management	A storage policy change was applied to a production prefix. Participants should test whether change approval, peer review, rollback, and post-change validation were adequate.
Cloud posture management	CSPM alert existed but was not escalated due to weak data classification and alert severity logic. Participants should define a better severity model.
Data classification	Sensitive data repository lacked or had incomplete classification tags. Participants should assess how data classification affects alerting, access control, retention, and notification.
Repository ownership	Technical ownership, application ownership, and data ownership may not align. Participants should determine who is accountable for permissions and monitoring.
Enterprise validation	Participants should define how similar public exposures will be found across all storage accounts, subscriptions, projects, regions, and business units.

Technical evidence package to request

- Storage policy and access control state before and after containment.
- Management-plane audit logs showing policy changes, actor identity, change ticket reference, and timestamp.
- Object-level access logs for the available retention period, including unauthenticated GET/HEAD/List operations if available.
- CDN, WAF, reverse proxy, and application logs for document preview and upload paths.
- Object inventory by prefix, customer mapping, file type, creation date, last modified date, and classification.
- CSPM findings, alert history, ownership metadata, and data classification tags.
- Change ticket, peer review notes, approval trail, rollback plan, and post-change validation evidence.
- Screenshots and URLs from researcher submission, preserved with chain-of-custody notes.

12. Business Impacts to Explore

Business impact	Stakeholders	Discussion focus
Customer trust erosion	Executives, communications, customer operations	How to communicate uncertainty with empathy and accuracy.
Regulatory scrutiny	Legal, compliance, privacy, executives	How to prepare a regulator-ready timeline, evidence package, and remediation plan.
Fraud and identity-theft risk	Fraud, privacy, customer support, business lines	How to decide monitoring, identity protection, and high-risk customer treatment.
Operational disruption	Business lines, digital platform, operations	Whether onboarding/mortgage intake should pause, continue, or operate under compensating controls.
Call center surge	Customer operations, communications, fraud	Scripts, escalation paths, identity-verification precautions, and staffing.
Media and reputational pressure	Communications, legal, executives	Holding statement, social monitoring, executive talking points, and misinformation management.
Board and senior leadership demands	Incident Commander, CISO, executives	SITREP cadence, decision log, risk acceptance, and control remediation commitments.

13. Facilitator Reference: Strong Response Indicators

Mature response indicators

- Rapid validation of researcher report using controlled procedures.
- Clear incident command structure, cadence, and decision log within the first hour.
- Immediate containment authority understood and executed by SOC/cloud teams without unnecessary crisis-cell delay.
- Evidence preservation before and after containment, including policy snapshots, logs, screenshots, metadata, and chain-of-custody notes.
- Cross-functional triage across cyber, cloud, business, privacy, legal, compliance, fraud, communications, and customer operations.
- Exposure scope based on data categories, object counts, affected customers, exposure window, and log limitations.
- Decision-making under uncertainty with clear distinction between facts, assumptions, unknowns, and risk decisions.
- Regulator/customer notification analysis launched early, not left until perfect technical certainty.
- Customer protection and fraud monitoring considered before public pressure peaks.
- Enterprise cloud exposure review and measurable remediation plan defined beyond the single repository.

Potential weaknesses to watch for

- Delayed containment because no one knows who owns cloud permissions.
- Overconfidence that no access occurred because logs are incomplete or because no bulk download is visible.
- Treating a privacy incident as only a technical ticket, or treating a cloud misconfiguration as if it were ransomware.
- Unclear decision rights between SOC, incident command, crisis leadership, legal, and business line owners.
- Failure to preserve current policy state and logs before making changes.
- No impact-banding approach for confirmed, probable, and possible affected customers.
- Inconsistent communications across executives, relationship managers, customer support, and media channels.
- Remediation statements that are generic, unowned, or not measurable.
- MITRE ATT&CK mapping that overstates attack phases not established by the scenario.

Observer scorecard

Score	Meaning	Observer guidance
1 - Not demonstrated	Capability absent or unclear.	Participants did not identify ownership, action, or decision path.
2 - Partially demonstrated	Some relevant actions discussed but incomplete.	Decision rights, evidence, or follow-through were unclear.
3 - Demonstrated	Capability present at a basic level.	Participants produced a plausible decision or output with some gaps.
4 - Strongly demonstrated	Capability mature and practical.	Clear ownership, evidence, timing, and dependencies were captured.
5 - Leading practice	Capability is robust, measurable, and tested.	Participants anticipated downstream impacts and defined validation evidence.

14. Debrief Questions

First-hour response

- What went well in the first hour?
- How quickly did the team validate the researcher report?
- Was containment authority clear?
- Were logs, screenshots, policies, and object metadata preserved before changes?

- Was the incident commander identified and empowered?

Scoping and evidence

- How confident are we in determining exposure duration, affected customers, and data categories?
- Did the team separate confirmed facts from assumptions and unknowns?
- How did incomplete logs affect decisions?
- What additional telemetry would have materially improved confidence?

Governance and communications

- Where did decision ownership become unclear?
- Were legal, privacy, compliance, fraud, communications, and customer operations engaged at the right time?
- Were regulator, customer, employee, executive, and media messages aligned?
- Was the board or executive committee escalation threshold clear?

Control improvement

- What cloud governance controls would have prevented or detected this scenario earlier?
- Which repositories, applications, and business processes require broader validation?
- Which actions can be completed in 7 days, 30 days, and 60-90 days?
- What evidence will prove that corrective actions are complete and effective?
- What capability should be tested again in the next tabletop or technical simulation?

15. Improvement Planning Template

Timeframe	Recommended actions	Owner examples	Evidence of completion
Immediate actions (0-7 days)	- Confirm containment and preserve evidence. - Complete initial object inventory and customer impact bands. - Complete legal/privacy notification analysis. - Prepare customer support and fraud monitoring. - Issue executive summary and incident timeline. - Launch emergency review for public exposure on sensitive repositories.	Incident Commander, SOC, Cloud Engineering, Privacy, Legal, Compliance, Fraud, Communications, Business Owner	Containment timestamp, evidence archive, decision log, notification memo, support scripts, initial cloud exposure scan results.
Near-term actions (30 days)	- Enforce public access block on sensitive storage accounts. - Require object-level logging for regulated data repositories. - Improve CSPM alert severity using data classification tags. - Tighten approval workflow for storage permission changes. - Update cloud incident response playbooks and researcher disclosure process. - Validate contact center and media holding templates.	Cloud Security, IAM, Platform Engineering, Data Governance, IR Lead, Communications	Policy-as-code checks, logging retention report, updated playbook, alert tuning, change-control evidence, approved templates.
Medium-term actions (60-90 days)	- Implement preventive guardrails and continuous posture monitoring. - Complete enterprise data classification and repository ownership mapping. - Integrate cloud logs into SIEM with alerting on public access, large downloads, and unusual access geography. - Conduct a technical simulation to validate detection and containment. - Report closure status to executive risk committee.	CISO, Cloud Security, Data Governance, SOC Engineering, Enterprise Risk, Business Owners	Control validation report, SIEM detections, CSPM dashboard, simulation report, risk committee closure evidence.

Action tracker fields

- Finding / gap
- Risk statement
- Corrective action
- Owner
- Due date
- Dependencies

- Status
- Evidence required for closure
- Residual risk decision, if any

16. Optional Exercise Artifacts

Facilitators may prepare or display the following synthetic artifacts. These artifacts should be clearly marked as exercise material and must not contain real customer data.

Artifact	Purpose	Suggested content
Sample researcher email	Initiates inject 1 and tests responsible disclosure workflow.	Researcher name, timestamp, redacted examples, public URL paths, request for acknowledgment, safe-harbor question.
Screenshot of public URL path	Supports validation and evidence preservation discussion.	Redacted customer document displayed from unauthenticated browser session; timestamp and URL visible.
Cloud policy excerpt	Tests technical containment and root-cause analysis.	Storage policy showing unintended public read permission on production prefix and last modified timestamp.
Cloud log excerpt	Tests scoping under incomplete evidence.	GET/HEAD/List events for available log period, external IPs, user-agent strings, object paths, and log-coverage caveat.
Change ticket excerpt	Connects root cause to governance and change management.	Approved document-preview change, production prefix mismatch, rollback plan gap, post-change validation gap.
Executive situation report	Tests concise leadership reporting.	Timeline, facts, assumptions, customer impact bands, decisions needed, next update time.
Regulator notification decision memo	Tests legal/privacy/compliance decision quality.	Data categories, affected population estimate, exposure window, evidence gaps, notification recommendation, approvals.
Customer Q&A / contact center script	Tests customer operations readiness.	Plain-language explanation, what customers should do, identity verification guidance, escalation path.
Media holding statement	Tests communications discipline.	Acknowledgment of investigation, customer protection priority, commitment to facts, no unsupported claims.

Sample holding statement for exercise use

We are investigating a report involving potential unauthorized public access to a limited cloud document repository used for customer onboarding and mortgage workflows. We have taken steps to secure the affected storage location, are working to determine the scope and impact, and will notify affected parties and regulators as appropriate. Protecting customer information remains our priority.

Sample executive SITREP structure

- Situation: one-paragraph description of confirmed facts.
- Impact: affected data categories, customer bands, business process impacts, fraud/customer risk.
- Actions taken: validation, containment, evidence preservation, stakeholders engaged.
- Decisions needed: notification posture, workflow pause/continue, customer support, board/regulator escalation.
- Open questions: exposure duration, third-party access evidence, final customer counts.
- Next update: time, owner, and expected new information.

17. MITRE ATT&CK Mapping

This scenario is primarily a misconfiguration-driven cloud data exposure, not a classic multi-stage intrusion. The mapping below is intentionally narrow. It identifies behaviors reflected in the scenario and separates observed exercise facts from conditional techniques that should not be asserted unless the evidence emerges during facilitation.

Facilitator rule: ATT&CK mapping should follow the evidence. Logging gaps, weak visibility, or uncertainty are control weaknesses; they are not automatically adversary defense evasion.

Tactic	Technique	Status	Scenario evidence	Facilitator guidance
TA0007 - Discovery	T1619 - Cloud Storage Object Discovery	Observed if inject evidence is used	Public listing was enabled for one prefix during part of the exposure window; available logs show limited HEAD/List-style discovery activity against object paths.	Ask what evidence proves enumeration occurred: List operations, repeated HEADs, object-prefix browsing, or researcher-provided object list.
TA0009 - Collection	T1530 - Data from Cloud Storage Object	Observed	Researcher accessed and provided redacted samples from cloud object storage. Logs show unauthenticated GET requests to document objects during available log window.	Map only to the specific collection behavior. Do not infer account compromise or malware.
TA0010 - Exfiltration	T1020 - Automated Exfiltration	Conditional / not observed	No mass automated download is visible in available logs. This becomes relevant only if evidence shows scripted bulk retrieval or scheduled transfer.	Use as a discussion trigger for detection thresholds, not as an asserted scenario fact.
TA0010 - Exfiltration	T1567 - Exfiltration Over Web Service	Conditional / not observed	No evidence that a malicious actor moved stolen data to an adversary-controlled web or cloud service.	Do not map merely because exposed data was reachable over HTTPS. Require evidence of transfer to an external service controlled by the actor.
TA0007 - Discovery	T1580 - Cloud Infrastructure Discovery	Conditional / not observed	No authenticated cloud account discovery or broad resource enumeration is established.	Use only if a later branch introduces authenticated enumeration of storage services, buckets, or cloud resources.
TA0005 - Defense Evasion	No technique mapped	Excluded	Incomplete logging and missed CSPM alert are defender control gaps, not evidence of adversary action to evade defenses.	Avoid mapping defense evasion unless the scenario introduces tampering, log deletion, or deliberate visibility impairment.
TA0007 - Discovery	T1083 - File and Directory Discovery	Excluded	T1083 is a local endpoint file-system technique and is less precise than cloud-specific object discovery for this scenario.	Prefer T1619 for cloud object enumeration when evidence supports it.

Data sources and detections to discuss

- Cloud storage access logs: object GET, HEAD, List, Copy, and download volume.
- Cloud storage enumeration telemetry: object prefix listing and unusual object discovery patterns.
- Management-plane audit logs: policy changes, IAM changes, public access block changes, and actor identity.
- CSPM findings: public access, missing classification tags, policy drift, and alert severity.
- Network/CDN/WAF logs: access paths, geolocation, user agents, status codes, and unusual retrieval patterns.
- SIEM detections: public access enabled on sensitive repository, unusual object access volume, access from new geographies, and object reads without authenticated organizational identity.

18. Source-to-Scenario Traceability

Source element	How it is reflected in this exercise
Banking organization with cloud-hosted onboarding and mortgage workflows	Scenario centers on a financial-services digital onboarding and mortgage document repository.
Cloud document storage containing onboarding documents, ID images, and mortgage artifacts	Data categories include identity documents, onboarding forms, proof-of-address, income documentation, and mortgage application artifacts.
Cloud storage misconfiguration enabling unauthenticated public access	Narrative defines a production object storage policy and public link-sharing rule that expose a document prefix.
External researcher disclosure	Inject 1 begins with a responsible-disclosure report and redacted evidence.
Scoping, access evidence, and notification dilemma	Inject 2 introduces object inventory, logging gaps, external access evidence, and legal/privacy notification decisions.
Media and operational pressure	Inject 3 introduces journalist inquiry, workflow continuation decision, fraud monitoring, and customer support readiness.
Containment and governance remediation	Inject 4 focuses on root cause, residual uncertainty, notification recommendation, and control uplift plan.
Evaluation feedback on realism and coherence	The revised design adds cloud service behavior, storage policy history, logging sources, control-state detail, and explicit causal chain.
Evaluation feedback on MITRE accuracy	The revised ATT&CK mapping narrows observed techniques to evidenced cloud behaviors and separates conditional or excluded techniques.
Evaluation feedback on structural completeness	The revised design adds evaluation criteria, observer scorecard, inject delivery artifacts, escalation mechanics, success indicators, and action tracking.

19. Suggested Title for Distribution

Cloud Misconfiguration Exposing KYC and Mortgage Documents - Cyber Tabletop Exercise

Alternate internal title: Public Cloud Document Repository Exposure - Digital Onboarding and Mortgage Workflow TTX.

End of exercise design.